

INTRODUCTION TO SECURITY

After completing this module, you should be able to do the following:

- 1 Define information security and explain why it is important
- 2 Identify threat actors and their attributes
- 3 Describe the different types of vulnerabilities and attacks
- 4 Explain the impact of attacks

Front-Page Cybersecurity

Threat actors have a long history of using current events to take advantage of distracted and unsuspecting users. For example, whenever a natural disaster such as a hurricane or flood occurs, unscrupulous attackers send out email messages with tempting subject lines such as “Contribute to Disaster Relief Here” or “These Flood Pictures Are Unbelievable!” These messages are, of course, intended to trick a user to open an email attachment that contains malware or click a hyperlink that redirects them to a malicious website.

The 2020 pandemic caused by the coronavirus disease (COVID-19) was no exception. Threat actors used this tragic worldwide event as cover for their attacks. A variety of campaigns distributed malware, stole user credentials, and scammed victims out of their money.

Many email scams offered to sell hard-to-find face masks or even medication to cure COVID-19 infections. Some scams asked for investments in fake companies that claimed to be developing vaccines, while other email scams asked for donations to fictitious charities, such as the World Health Community. (This organization does not exist, but the name is similar enough to the World Health Organization to cause confusion.)

Some malicious emails were designed to infect a victim’s computer with malware. Email subject lines such as a “Breaking Coronavirus News Update” or “You Must Do This Right Now!” were common and caused anxious victims to open an attachment that infected their computer. Often emails that pretended to come from the Centers of Disease Control and Prevention (CDC) claimed to contain a list of new COVID-19 cases in the vicinity and included the instructions, “You are instructed to immediately read this list of cases to avoid potential hazards.” Unfortunately, opening the attachment installed malware on the computer and stole user passwords.¹

In one particularly egregious email attack, the threat actors claimed to have access to personal information about the email recipient, including where they lived. The attackers threatened to visit the user to infect them and their family with COVID-19 unless a ransom was paid online. Over a span of two days, this attack was detected more than 1,000 times.

Perhaps the award for the most innovative attack goes to the AI Corona Antivirus website. This site advertised “Corona Antivirus—World’s best protection.” Downloading and installing its digital “AI Corona Antivirus” would protect the computer

from digital malware infections and keep the user from being infected by the biological COVID-19. In case someone might be skeptical that downloading and installing computer antivirus software would protect them from COVID-19, the website claimed proof that their product actually worked: “Our scientists from Harvard University have been working on a special AI development to combat the virus using a Windows app. Your PC actively protects you against the coronaviruses while the app is running.”

However, downloading the AI Corona Antivirus software on a computer did not protect the user from the biological COVID-19—though it took several other actions. It turned the computer into a launching pad to attack other computers. It also took screenshots of what was displayed on the monitor, stole web browser cookies and saved passwords, installed a program to capture keystrokes, and even took any Bitcoin wallets saved on the computer.²

How many cyberattacks have you heard about over the past month? The past week? Even today? The number of attacks has reached astronomical proportions. According to one report, the number of new malware releases every month exceeds 20 million, and the total malware in existence is approaching 900 million instances.³ In 2019, four out of every five organizations experienced at least one successful cyberattack, and more than one-third suffered six or more successful attacks.⁴ It is estimated that by 2021, a business will fall victim to a ransomware attack once every 11 seconds. Cybercrime will cost the world \$6 trillion annually by 2021, an increase of 100 percent in just six years, representing the greatest transfer of economic wealth in human history.⁵ Compounding the problem, 85 percent of organizations are experiencing a shortfall of skilled security professionals.⁶ The dismal numbers go on and on.

The need to identify and defend against these constant attacks has created an essential workforce that is now at the core of the information technology (IT) industry. Known as *information security*, personnel in this field are focused on protecting electronic information. Various elements of information security—such as *application security*, *infrastructure security*, *forensics and malware analysis*, and *security leadership*, along with several others—make up this workforce.

The information security workforce is usually divided into two broad categories. Information security *managerial personnel* administer and manage plans, policies, and people, while information security *technical personnel* are concerned with designing, configuring, installing, and maintaining technical security equipment. Within these two broad categories are four generally recognized types security positions:

- **Chief information security officer (CISO).** This person reports directly to the chief information officer (CIO). (Large enterprises may have more layers of management between this person and the CIO.) The CISO is responsible for assessing, managing, and implementing security.
 - **Security manager.** The security manager reports to the CISO and supervises technicians, administrators, and security staff. Typically, a security manager works on tasks identified by the CISO and resolves issues identified by technicians. This position requires an understanding of configuration and operation but not necessarily technical mastery.
 - **Security administrator.** The security administrator has both technical knowledge and managerial skills. A security administrator manages daily operations of security technology and may analyze and design security solutions within a specific entity as well as identifying users' needs.
 - **Security technician.** This position is generally entry level for a person who has the necessary technical skills. Technicians provide technical support to configure security hardware, implement security software, and diagnose and troubleshoot problems.

NOTE 1

The job outlook for security professionals is exceptionally strong. According to the U.S. Bureau of Labor Statistics (BLS) “Occupational Outlook Handbook,” the job outlook for information security analysts through 2024 is expected to grow by 18 percent, much faster than the average job growth rate.⁸ One report states that by the end of the decade, demand for security professionals worldwide will rise to 6 million, with a projected shortfall of 1.5 million unfilled positions.⁹

As noted earlier, organizations have a desperate need for trained security personnel. The number of unfilled cybersecurity positions has increased by 50 percent since 2015.⁷ By some estimates, 3.5 million positions will open by 2021.

When filling cybersecurity positions, an overwhelming majority of enterprises use the Computing Technology Industry Association (CompTIA) Security+ certification to verify security competency. Of the hundreds of security certifications currently available, Security+ is one of the most widely acclaimed security certifications.

Because it is internationally recognized as validating a foundation level of security skills and knowledge, the Security+ certification has become the foundation for today's IT security professionals.

NOTE 2

The value for an IT professional who holds a CompTIA security certification is significant. On average, an employee with a CompTIA certification commands a salary from 5 to 15 times higher than their counterparts with similar qualifications but lacking a certification.¹⁰

The CompTIA Security+ certification is a vendor-neutral credential that requires passing the current certification exam, SY0-601. A successful candidate has the knowledge and skills required to identify attacks, threats, and vulnerabilities; design a strong security architecture; implement security controls, be knowledgeable of security operations and incident response; and be well versed in governance, risk, and compliance requirements.

NOTE 3

The CompTIA Security+ certification meets the ISO 17024 standard and is approved by U.S. Department of Defense (DoD) to fulfill multiple levels of the DoD 8140 directive, which is an expansion of and replacement for the earlier DoD 8570 directive. This directive outlines which cybersecurity certifications are approved to validate the skills for certain job roles.

This module introduces the security fundamentals that form the basis of the Security+ certification. It begins by defining information security and then examines the attackers and how they function. It also covers vulnerabilities, categories of attacks, and the impacts of attacks.

WHAT IS INFORMATION SECURITY?

The first step in a study of information security is to define exactly what it is. This involves examining the definition of security and how it relates to information security.

Understanding Security

What is *security*? The word comes from Latin, meaning *free from care*. Sometimes security is defined as *the state of being free from danger*, which is the *goal* of security. It is also defined as the *measures taken to ensure safety*, which is the *process* of security. Since complete security can never be fully achieved, the focus of security is more often on the process instead of the goal. In this light, security can be defined as *the necessary steps to protect from harm*.

The relationship between *security* and *convenience* is *inversely proportional* (the symbol α), as illustrated in Figure 1-1: as security is increased, convenience is decreased. That is, the more secure something is, the less convenient it may become to use. Consider a house in which the homeowner installs an automated alarm system. The alarm requires a resident to enter a code on a keypad within 30 seconds of entering the house. Although the alarm system makes the house more secure, it is less convenient to race to the keypad than to casually walk into the house.

NOTE 4

Security is often described as *sacrificing convenience for safety*.

Defining Information Security

Several terms describe security in an IT environment: *computer security*, *IT security*, *cybersecurity*, and *information assurance*, to name just a few. Whereas each has its share of proponents and slight variations of meanings, the term *information security* may be the most appropriate because it is the broadest: protecting information from harm. Information security is often used to describe the tasks of securing digital information, whether it is manipulated by a microprocessor (such as on a personal computer), preserved on a storage device (such as a hard drive or USB flash drive), or transmitted over a network (such as a local area network or the Internet).

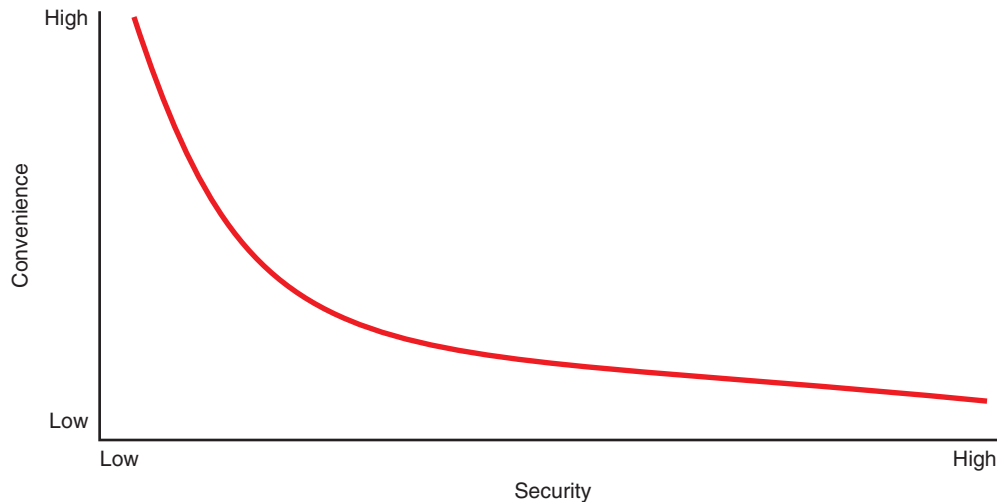


Figure 1-1 Relationship of security to convenience



CAUTION

Information security should not be viewed as a war to win or lose. Just as crimes such as burglary can never be completely eradicated, neither can attacks against technology devices. The goal is not achieving complete victory but instead maintaining equilibrium: as attackers take advantage of a weakness in a defense, defenders must respond with an improved defense. Information security is an endless cycle between attacker and defender.

Information security cannot completely prevent successful attacks or guarantee that a system is totally secure, just as the security measures taken for a house can never guarantee complete safety from a burglar. The goal of information security is to ensure that protective measures are properly implemented to ward off attacks, prevent the total collapse of the system when a successful attack does occur, and recover as quickly as possible. Thus, information security is first *protection*.

Second, information security is intended to protect *information* that provides value to people and enterprises. Known as the *CIA Triad*, three protections must be extended over information:

1. **Confidentiality.** Only approved individuals should be able to access sensitive information. For example, the credit card number used to make an online purchase must be kept secure and unavailable to unapproved entities. *Confidentiality* ensures that only authorized parties can view the information. Providing confidentiality can involve several security tools, ranging from software to encrypt the credit card number stored on the web server to door locks to prevent access to those servers.
2. **Integrity.** *Integrity* ensures that the information is correct and no unauthorized person or malicious software has altered the data. In the example of an online purchase, an attacker who could change the amount of a purchase from \$10,000.00 to \$1.00 would violate the integrity of the information.
3. **Availability.** Information has value if the authorized parties who are assured of its integrity can access the information. *Availability* ensures that data is accessible to only authorized users and not to unapproved individuals. For example, the total number of items ordered as the result of an online purchase must be made available to an employee in a warehouse so that the correct items can be shipped to the customer, but the information should not be available to a competitor.

Because information is stored on computer hardware, manipulated by software, and transmitted by communications, each of these areas must be protected. The third objective of information security is to protect the integrity, confidentiality, and availability of information *on the devices that store, manipulate, and transmit the information*.

Protection is achieved through a process that combines three entities. As shown in Figure 1-2, information and hardware, software, and communications are protected in three layers: *products, people, and policies and procedures*. The procedures enable people to understand how to use products to protect information.

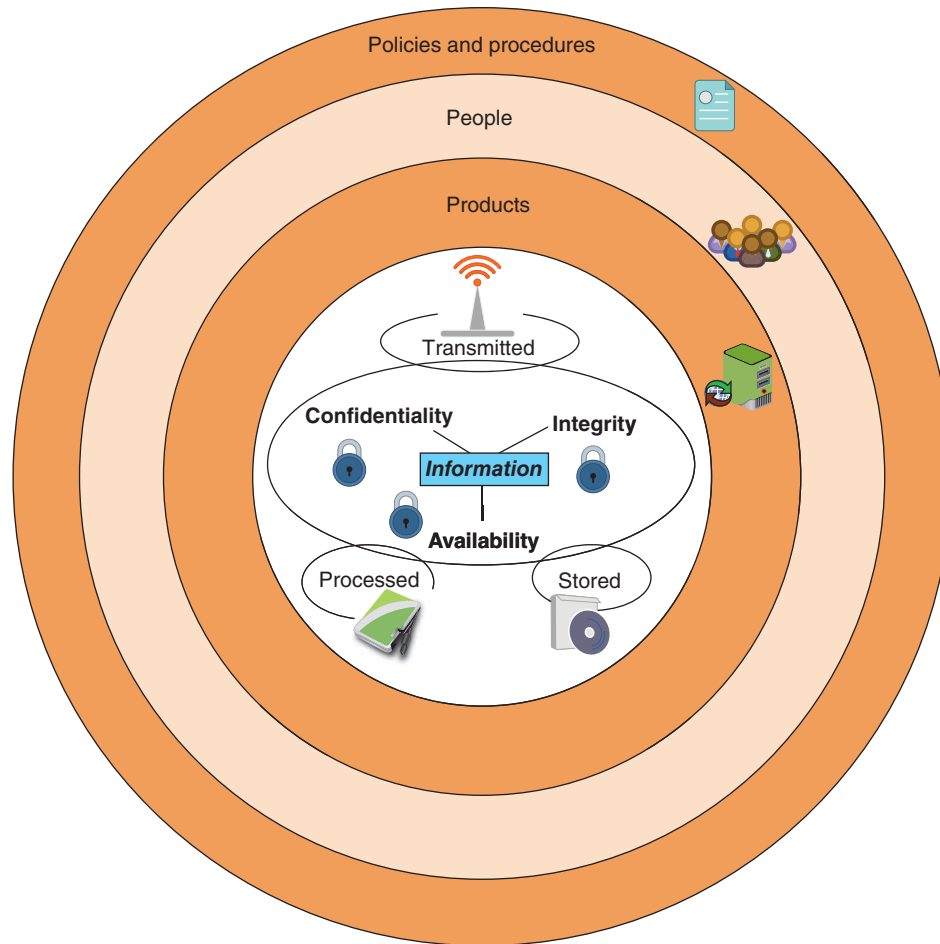


Figure 1-2 Information security layers

Thus, information security may be defined as *that which protects the integrity, confidentiality, and availability of information through products, people, and procedures on the devices that store, manipulate, and transmit the information.*

TWO RIGHTS & A WRONG

1. A security manager works on tasks identified by the CISO and resolves issues identified by technicians.
2. Since 2015, the number of unfilled cybersecurity positions has increased by 10 percent.
3. The relationship between security and convenience is inversely proportional: as security is increased, convenience is decreased.

See Appendix B for the answer.

WHO ARE THE THREAT ACTORS?

CERTIFICATION

1.5 Explain different threat actors, vectors, and intelligence sources.

In cybersecurity, a **threat actor** (also called a *malicious actor*) is an individual or entity responsible for cyber incidents against the technology equipment of enterprises and users. The generic term *attacker* is also commonly used.

The very first cyberattacks were mainly for the threat actors to show off their technology skills (*fame*). However, that soon gave way to threat actors with the focused goal of financial gain (*fortune*). Financial cybercrime is often divided into three categories based on its targets:

- **Individual users.** The first category focuses on individuals as the victims. The threat actors steal and use stolen data, credit card numbers, online financial account information, or Social Security numbers to profit from their victims or send millions of spam emails to peddle counterfeit drugs, pirated software, fake watches, and pornography.
- **Enterprises.** The second category focuses on enterprises and business organizations. Threat actors attempt to steal research on a new product so that they can sell it to an unscrupulous foreign supplier who then builds an imitation model of the product to sell worldwide. This deprives the legitimate business of profits after investing hundreds of millions of dollars in product development, and because these foreign suppliers are in a different country, they are beyond the reach of domestic enforcement agencies and courts.
- **Governments.** Governments are also the targets of threat actors. If the latest information on a new missile defense system can be stolen, it can be sold—at a high price—to that government's enemies. In addition, government information is often stolen and published to embarrass the government in front of its citizens and force it to stop what is considered a nefarious action.

The **attributes**, or characteristic features, of the groups of threat actors can vary widely. Some groups have a high level of power and complexity (called **level of capability/sophistication**) with a massive network of resources, while others are “lone wolves” with minimal skills and no resources. In addition, some groups have deep **resources and funding** while others have none. Whereas some groups of threat actors may work within the enterprise (**internal**), others are strictly outside the organization (**external**). Finally, the **intent/motivation**—that is, the reason for the attacks—of the threat actors also varies widely.

In the past, the term **hacker** referred to a person who used advanced computer skills to attack computers. Because that title often carried a negative connotation, it was qualified in an attempt to distinguish between different types of the attackers. The types of hackers are summarized in Table 1-1.

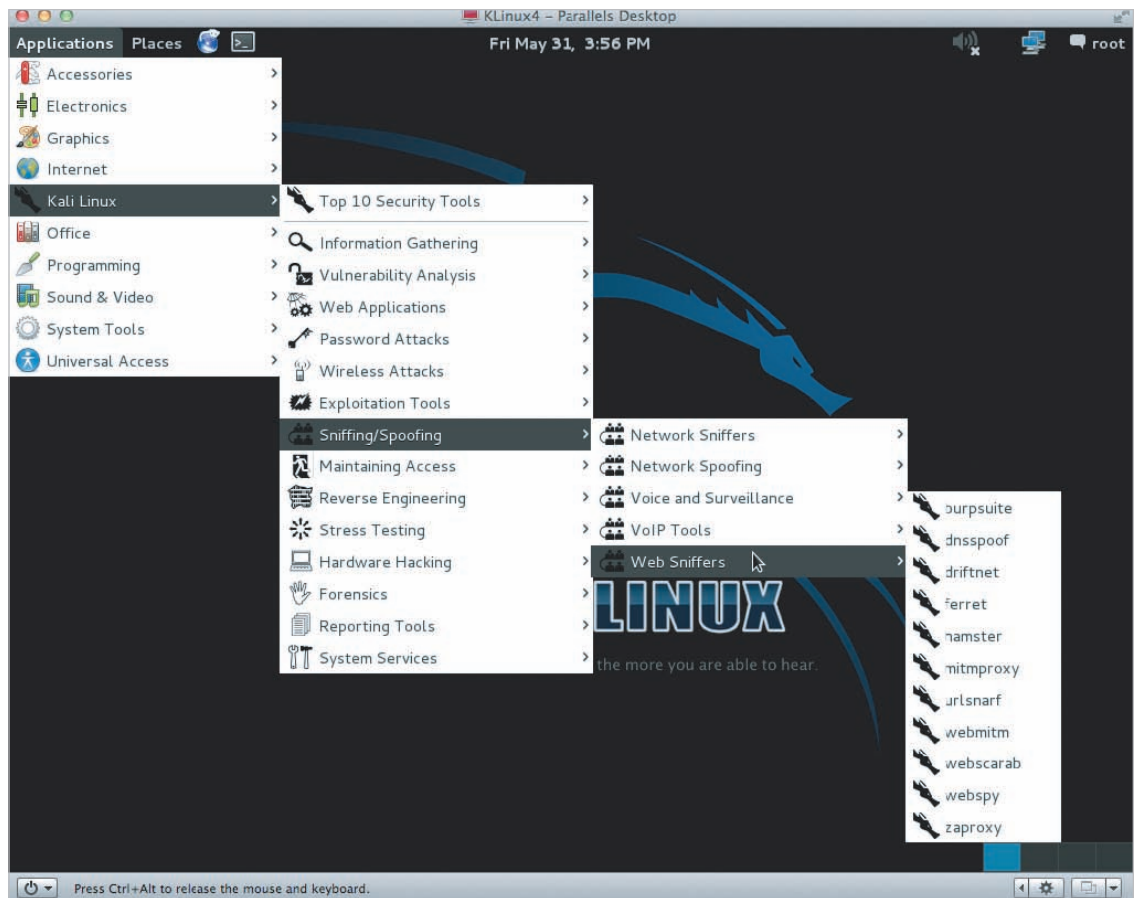
Table 1-1 Types of hackers

Hacker Type	Description
Black hat hackers	Threat actors who violate computer security for personal gain (such as to steal credit card numbers) or to inflict malicious damage (corrupt a hard drive).
White hat hackers	Also known as <i>ethical attackers</i> , they attempt to probe a system (with an organization's permission) for weaknesses and then privately provide that information back to the organization.
Gray hat hackers	Attackers who attempt to break into a computer system without the organization's permission (an illegal activity) but not for their own advantage; instead, they publicly disclose the attack in order to shame the organization into taking action.

However, these broad categories of hackers no longer accurately reflect the differences between attackers. Today threat actors are classified in more distinct categories, such as script kiddies, hacktivists, state actors, insiders, and others.

Script Kiddies

Script kiddies are individuals who want to perform attacks, yet lack the technical knowledge to carry them out. Script kiddies instead do their work by downloading freely available automated attack software (*scripts*) and use it to perform malicious acts. Figure 1-3 illustrates a widely available software package that launches a sophisticated attack when a user simply makes selections from a menu. Due to their lack of knowledge, script kiddies are not always successful in penetrating defenses, but when they are, they may end up causing damage to systems and data instead of stealing the data.



Source: Kali Linux

Figure 1-3 Menu of attack tools

Hacktivists

Individuals that are strongly motivated by ideology (for the sake of their principles or beliefs) are **hacktivists** (a combination of the words *hack* and *activism*). Most hacktivists do not explicitly call themselves “hacktivists,” but the term is commonly used by security researchers and journalists to distinguish them from other types of threat actors.

In the past, the types of attacks by hacktivists often involved breaking into a website and changing its contents as a means of making a political statement. (One hacktivist group changed the website of the U.S. Department of Justice to read *Department of Injustice*.) Other attacks were retaliatory: hacktivists have disabled a bank’s website because the bank stopped accepting online payments deposited into accounts belonging to groups supported by the hacktivists. Today many hacktivists work through disinformation campaigns by spreading fake news and supporting conspiracy theories.

NOTE 5

Hacktivists were particularly active during the coronavirus disease (COVID-19) pandemic of 2020. One large group of what were considered far-right neo-Nazi hacktivists embarked on a months-long disinformation campaign designed to weaponize the pandemic by questioning scientific evidence and research. In another instance, thousands of breached email addresses and passwords from U.S. and global health organizations—including the U.S. National Institutes of Health, CDC, and the World Health Organization—were distributed on Twitter by these groups to harass and distract the health organizations.

State Actors

Instead of using an army to march across the battlefield to strike an adversary, governments are increasingly employing their own state-sponsored attackers for launching cyberattacks against their foes. These attackers are known as **state actors**. Their foes may be foreign governments or even citizens of their own nation that the government considers

hostile or threatening. A growing number of attacks from state actors are directed toward businesses in foreign countries with the goal of causing financial harm or damage to the enterprise's reputation.

Many security researchers believe that state actors might be the deadliest of any threat actors. When fortune motivates a threat actor, but the target's defenses are too strong, the attacker simply moves on to another promising target with less effective defenses. State actors, however, have a specific target and keep working until they are successful. They are highly skilled and have enough government resources to breach almost any security defense.

State actors are often involved in multiyear intrusion campaigns targeting highly sensitive economic, proprietary, or national security information. The campaigns have created a new class of attacks called **advanced persistent threat (APT)**. The attacks use innovative tools (*advanced*) and once a system is infected, they silently extract data over an extended period of time (*persistent*). APTs are most commonly associated with state actors.

Insiders

Another serious threat to an enterprise comes from its own employees, contractors, and business partners, called *insiders*, who pose an **insider threat** of manipulating data from the position of a trusted employee. For example, a health-care worker disgruntled about being passed over for a promotion might illegally gather health records on celebrities and sell them to the media, or a securities trader who loses billions of dollars on bad stock bets could use her knowledge of the bank's computer security system to conceal the losses through fake transactions. These attacks are harder to recognize because they come from within the enterprise, yet they may be costlier than attacks from the outside.

Six out of 10 enterprises reported being a victim of at least one insider attack during 2019. The focus of the insiders was intellectual property (IP) theft (43 percent), sabotage (41 percent), and espionage (32 percent).¹¹ Because most IP thefts occur within 30 days of an employee resigning, the insiders may believe that either the IP belongs to them instead of the enterprise or that they were not properly compensated for their work on the IP. In recent years, government insiders have stolen large volumes of sensitive information and then published it to alert its citizens of clandestine governmental actions.

Other Threat Actors

Other categories of threat actors are summarized in Table 1-2.

Table 1-2 Descriptions of other threat actors

Threat Actor	Description	Explanation
Competitors	Launch attacks against an opponent's system to steal classified information.	May steal new product research or a list of current customers to gain a competitive advantage.
Criminal syndicates	Move from traditional criminal activities to more rewarding and less risky online attacks.	Usually run by a small number of experienced online criminal networks that do not commit crimes themselves but act as entrepreneurs.
Shadow IT	Employees become frustrated with the slow pace of acquiring technology, so they purchase and install their own equipment or resources in violation of company policies.	Installing personal equipment, unauthorized software, or using external cloud resources can create a weakness or expose sensitive corporate data.
Brokers	Sell their knowledge of a weakness to other attackers or governments.	Individuals who uncover weaknesses do not report it to the software vendor but instead sell them to the highest bidder who is willing to pay a high price for the unknown weakness.
Cyberterrorists	Attack a nation's network and computer infrastructure to cause disruption and panic among citizens.	Targets may include a small group of computers or networks that can affect the largest number of users, such as the computers that control the electrical power grid of a state or region.

 CAUTION

Often the perception of an attacker by the general public is a “hacker in a hoodie,” a disgruntled teenager looking for an easy target. Nothing could be further from the truth. Threat actors today generally have excellent technology skills, are tenacious, and have strong financial backing. Attackers have even modeled their work after modern economic theories (such as finding the optimum “price point” in which victims will pay a ransom) and software development (attack tools that threat actors sell are often software suites that receive regular updates). It is a serious mistake to underestimate modern threat actors.

TWO RIGHTS & A WRONG

1. Script kiddies are responsible for the class of attacks called advanced persistent threats.
2. Hacktivists are strongly motivated by ideology.
3. Brokers sell their knowledge of a weakness to other attackers or a government.

See Appendix B for the answer.

VULNERABILITIES AND ATTACKS

 CERTIFICATION

- 1.1 Compare and contrast different types of social engineering techniques.
- 1.5 Explain different threat actors, vectors, and intelligence sources.
- 1.6 Explain the security concerns associated with various types of vulnerabilities.

When exploiting vulnerabilities, threat actors use several avenues for their attacks. However, one of the most successful types of attack—social engineering—does not even exploit technology vulnerabilities. Regardless of how attacks occur, each successful attack has serious ramifications.

Vulnerabilities

A *vulnerability* (from Latin meaning *wound*) is defined as the state of being exposed to the possibility of being attacked or harmed. Cybersecurity vulnerabilities can be categorized into platforms, configurations, third parties, patches, and zero-day vulnerabilities.

Platforms

Several vulnerabilities are the result of the *platform* being used. (A computer platform is a system that consists of the hardware device and an operating system (OS) that runs software such as applications, programs, or processes.) Although all platforms have vulnerabilities to some degree, some platforms by their very nature have more serious vulnerabilities. These include legacy platforms, on-premises platforms, and cloud platforms.

Legacy Platforms One type of platform that is well known for its vulnerabilities is a legacy platform. A **legacy platform** is no longer in widespread use, often because it has been replaced by an updated version of the earlier technology. Although legacy hardware introduces some vulnerabilities, more often vulnerabilities result from legacy software, such as an OS or program.

Modern OS software, such as Microsoft Windows, Apple macOS, and Linux, continually evolve and are updated with new enhancements and—most critically—fixes to uncovered vulnerabilities. For a variety of reasons—limited hardware capacity, an application that only operates on a specific OS version, or even neglect—an OS may not be updated, thus depriving it of these security fixes. This creates a legacy platform just asking to be attacked.

NOTE 6

Prior to Microsoft Windows 10, all versions of the OS had a *Fixed Lifecycle Policy* with published end-of-support dates. For instance, Windows 7 was first released in October 2009, it was no longer available for purchase in October 2016, and all support ceased in January 2020. Windows 10, however, introduced the *Modern Lifecycle Policy* in which Windows 10 versions receive continuous support and servicing.

On-Premises Platforms Another platform that has significant vulnerabilities is the **on-premises platform**. On-premises (“on-prem”) is the software and technology located within the physical confines of an enterprise, which is usually consolidated in the company’s *data center*. At one time, the on-premises platform was considered the secure model of computing: an organization’s servers and data were protected behind its firewalls to prevent attacks.

However, this model proved to be faulty. Organizations found that they had to add more servers, network resources, support for remote access, and new software to support emerging business processes and user needs. This often resulted in a hodgepodge of resources that were quickly provisioned but not adequately configured for security. In addition, numerous entry points from the outside into the on-premises platform (through USB flash drives, wireless network transmissions, mobile devices, and email messages, for example) made protecting the on-premises platform an ever-changing and never-ending challenge.

Cloud Platforms Forty years ago, as computing technology became widespread, enterprises employed an on-premises model, in which they purchased all the hardware and software necessary to run the organization. As more resources were

needed, more purchases were made, and more personnel were hired to manage the technology. Because this resulted in spiraling costs, some enterprises turned to *hosted services*.

In a hosted services environment, servers, storage, and the supporting networking infrastructure are shared by multiple enterprises over a remote network connection that has been contracted for a specific period of time. As more resources are needed (such as additional storage space or computing power), the enterprise contacts the hosted service, negotiates an additional fee, and signs a new contract for those new services.

Today a new model is gaining widespread use. Known as a **cloud platform**, this is a pay-per-use computing model in which customers pay only for the online computing resources they need. As computing needs increase or decrease, cloud computing resources can be scaled up or scaled back.

However, cloud platforms have proven to have significant vulnerabilities. The vulnerabilities are most often based on misconfigurations by the company personnel responsible for securing the cloud platform. Cloud resources are, by definition, accessible from virtually anywhere, putting cloud computing platforms constantly under attack from threat actors probing for vulnerabilities.

Configurations

Modern hardware and software platforms provide an array of features and security settings that must be properly configured to repel attacks. However, the configuration settings are often not properly implemented, resulting in **weak configurations**. Table 1-3 lists several weak configurations that can result in vulnerabilities.

Table 1-3 Weak configurations

Configuration	Explanation	Example
Default settings	Default settings are predetermined by the vendor for usability and ease of use (not for security) so the user can immediately begin using the product.	A router comes with a default password that is widely known.
Open ports and services	Devices and services are often configured to allow the most access so that the user can close ports that are specific to that organization.	A firewall comes with FTP ports 20 and 21 open.
Unsecured root accounts	A root account can give a user unfettered access to all resources.	A misconfigured cloud storage repository could give any user access to all data.

(continues)

Table 1-3 Weak configurations (*continued*)

Configuration	Explanation	Example
Open permissions	Open permissions are user access over files that should be restricted.	A user could be given <i>Read</i> , <i>Write</i> , and <i>Execute</i> privileges when she should have only <i>Read</i> privileges.
Insecure protocols	Also called <i>insecure protocols</i> , this configuration uses protocols for telecommunications that do not provide adequate protections.	An employee could use devices that run services with insecure protocols such as <i>Telnet</i> or <i>SNMPv1</i> .
Weak encryption	Users choosing a known vulnerable encryption mechanism.	A user could select an encryption scheme that has a known weakness or a key value that is too short.
Errors	Human mistakes in selecting one setting over another without considering the security implications.	An employee could use deprecated settings instead of current configurations.

Third Parties

Almost all businesses use external entities known as **third parties**. Examples of third parties are marketing agencies, landscapers, shredding contractors, and attorneys.

Many enterprises also use IT-related third parties due to their elevated level of expertise. For example, organizations often contract with third parties to assist them in developing and writing a software program or app. This is called **outsourced code development**. Also, many organizations rely on third-party **data storage** facilities for storing important data. This helps to reduce the capital expenditures associated with purchasing, installing, and managing new storage hardware and software but also can provide remote access to employees from almost any location.

With the sheer number of third parties used, it can be difficult to coordinate their diverse activities with the organization. **Vendor management** is the process organizations use to monitor and manage the interactions with all of their external third parties.

Almost all third parties today require access to the organization's computer network. Access gives external entities the ability to perform their IT-related functions (such as outsourced code development) and even do basic tasks such as submitting online invoices. Connectivity between the organization and the third party is known as **system integration**. However, the organization's systems are often not compatible with the third party's systems, requiring "workarounds," which can create vulnerabilities. In addition, not all organizations are equipped with the expertise to handle system integration (**lack of vendor support**).

One of the major risks of third-party system integration involves the principle of the weakest link. That is, if the security of the third party has any weaknesses, it can provide an opening for attackers to infiltrate the organization's computer network. This can be illustrated by a 2013 attack on the Target retail chain. A refrigeration, heating, and air-conditioning third-party subcontractor that worked at a number of Target stores and other top retailers was provided access to Target's corporate computer network. The access was intended to allow the subcontractor to monitor energy consumption and temperatures in the stores to save on costs and to alert store managers if the temperatures fluctuated outside of an acceptable range. However, threat actors were able to gain access to the third party's computer network and then pivot into the Target network, where they stole 40 million credit card numbers.

Patches

Early OSs were simply program loaders whose job was to launch applications. As more features and graphical user interfaces (GUIs) were added, OSs became more complex. The increased complexity introduced unintentional vulnerabilities that

NOTE 7

One of the most alarming recent unsecured root account vulnerabilities was revealed in 2017 on the Apple macOS High Sierra OS. A user could enter the word *root* in the username field of a login prompt, move the insertion point to the password field, and then press Enter. The user would then be logged in with root privileges.

NOTE 8

Microsoft's first operating system, MS-DOS v1.0, had 4,000 lines of code, while Windows 10 is estimated to have up to 50 million lines.

could be exploited by attackers. In addition, new attack tools made vulnerable what were once considered secure functions and services in operating systems.

To address the vulnerabilities in OSs that are uncovered after the software has been released, software developers usually deploy a software “fix.” A fix can come in a variety of formats. A security **patch** is an officially released software security update intended to repair a vulnerability.

However, as important as patches are, they can create vulnerabilities:

- *Difficulty patching firmware.* **Firmware**, or software that is embedded into hardware, provides low-level controls and instructions for the hardware. Updating firmware to address a vulnerability can often be difficult and requires specialized steps. Furthermore, some firmware cannot be patched.
- *Few patches for application software.* Outside of the major application software such as Microsoft Office, patches for applications are uncommon. In most cases, no automated process can identify which computers have installed the application, alert users to a patch, or to distribute the patch.
- *Delays in patching OSs.* Modern operating systems—such as Red Hat Linux, Apple macOS, Ubuntu Linux, and Microsoft Windows—frequently distribute patches. These patches, however, can sometimes create new problems, such as preventing a custom application from running correctly. Many organizations test patches when they are released to ensure that they do not adversely affect any customized applications. In these instances, the organization delays installing a patch from the developer’s online update service until the patch is thoroughly tested.

NOTE 9

A variation on a zero-day vulnerability is when the software developer is actively working on a patch, but the vulnerability is discovered by the threat actors who launch an attack before the patch is completed. This could occur when an independent security investigator instead of the software developer uncovers the vulnerability and then alerts the developer who begins work on a patch. However, in the interim, the information about the vulnerability leaks out or is even sold to attackers, who exploit the vulnerability while the developers rush to patch it.

Zero Day

As noted earlier, patches are created and distributed when the software developer learns of a vulnerability and corrects it. What happens if it is not the developer who uncovers the vulnerability, but a threat actor who finds it first? In this case, the vulnerability can be exploited by attackers before anyone else even knows it exists. This type of vulnerability is called a **zero day** because it provides zero days of warning.

Zero-day vulnerabilities are considered extremely serious: systems are open to attack with no specific patches available. However, other protections can mitigate a zero-day attack. For example, some protections use machine learning to collect data from previously detected exploits and create a baseline of safe system behavior that may help detect an attack based on a zero-day vulnerability.

Attack Vectors

An **attack vector** is a pathway or avenue used by a threat actor to penetrate a system. Although there are many specific types of attacks, like vulnerabilities, attack vectors can be grouped into the following general categories:

- *Email.* Almost 94 percent of all malware is delivered through email to an unsuspecting user.¹² The goal is to trick the user to open an attachment that contains malware or click a hyperlink that takes the user to a fictitious website.
- *Wireless.* Because wireless data transmissions “float” through the airwaves, they can be intercepted and read or altered by a threat actor if the transmission is not properly protected.
- *Removable media.* A removable media device, such as a USB flash drive, is a common attack vector. Threat actors have been known to infect USB flash drives with malware and leave them scattered in a parking lot or cafeteria. A well-intentioned employee will find the drive and insert it into his computer to determine its owner. However, once inserted, the USB flash drive will infect the computer.
- *Direct access.* A **direct access** vector occurs when a threat actor can gain direct physical access to the computer. Once the attacker can “touch” the machine, she can insert a USB flash drive with an alternative operating system and reboot the computer under the alternate OS to bypass the security on the computer.

- *Social media.* Threat actors often use social media as a vector for attacks. For example, an attacker may read social media posts to determine when an employee will be on vacation and then call the organization's help desk pretending to be that employee to ask for "emergency" access to an account.
- *Supply chain.* A **supply chain** is a network that moves a product from the supplier to the customer and is made up of vendors that supply raw material, manufacturers who convert the material into products, warehouses that store products, distribution centers that deliver them to the retailers, and retailers who bring the product to the consumer. Today's supply chains are global in scope: manufacturers are usually thousands of miles away overseas and not under the direct supervision of the enterprise selling the product. The fact that products move through many steps in the supply chain—and that some steps are not closely supervised—has opened the door for malware to be injected into products during their manufacturing or storage (called *supply chain infections*). Supply chains also serve as third-party vulnerabilities.



CAUTION

Supply chain infections are considered especially dangerous. Users are receiving infected devices at the point of purchase, unaware that a brand-new device may be infected. Also, there is rarely any way to contact users and inform them of an infected device. Because it is virtually impossible to closely monitor every step in the global supply chain, these infections cannot be easily prevented.

- *Cloud.* As enterprises move their computing resources to remote cloud servers and storage devices, threat actors take advantage of the complexity of these systems to find security weaknesses.

Social Engineering Attacks

Not all attacks rely on technology vulnerabilities; in fact, some cyberattacks use little if any technology to achieve their goals. **Social engineering** is a means of **eliciting information** (gathering data) by relying on the weaknesses of individuals. Information elicitation may be the goal of the attack, or the information may then be used for other attacks. Social engineering is also used as **influence campaigns** to sway attention and sympathy in a particular direction. These campaigns can be found exclusively on social media (**social media influence campaign**) or may be combined with other sources (**hybrid warfare influence campaign**).

Social engineering attacks usually rely on psychological principles. They also can involve physical procedures.

Psychological Principles

Many social engineering attacks rely on psychology to affect others mentally and emotionally rather than physically. At its core, social engineering relies on an attacker's clever manipulation of human nature to persuade the victim to provide information or take actions. Several basic principles make psychological social engineering highly effective. These are listed in Table 1-4 with the example of an attacker pretending to be the chief executive officer (CEO) calling the organization's help desk to reset a password.

Table 1-4 Social engineering effectiveness

Principle	Description	Example
Authority	To impersonate an authority figure or falsely cite their authority	"I'm the CEO calling."
Intimidation	To frighten and coerce by threat	"If you don't reset my password, I will call your supervisor."
Consensus	To influence by what others do	"I called last week, and your colleague reset my password."

(continues)

Table 1-4 Social engineering effectiveness (*continued*)

Principle	Description	Example
Scarcity	To refer to something in short supply	"I can't waste time here."
Urgency	To demand immediate action	"My meeting with the board starts in five minutes."
Familiarity	To give the impression the victim is well known and well received	"I remember reading a good evaluation on you."
Trust	To inspire confidence	"You know who I am."

Another technique is called **prepending**, which is influencing the subject before the event occurs. A common general example is a preview of a soon-to-be-released movie that begins with the statement, "The best film you will see this year!" By starting with the desired outcome ("The best film"), the statement influences the listener to think that way. Threat actors use prepending with social engineering attacks, such as including the desired outcome in a statement that uses the urgency principle, as in "You need to reset my password immediately because my meeting with the board starts in five minutes."

Because many of the psychological approaches involve person-to-person contact, attackers use a variety of techniques to gain trust. For example:

- *Provide a reason.* Many social engineering threat actors are careful to add a reason along with their request. Giving a rationalization and using the word "because" makes it more likely the victim will provide the information. For example, *I was asked to call you because the director's office manager is out sick today.*
- *Project confidence.* A threat agent is unlikely to generate suspicion if she enters a restricted area by calmly walking through the building as if she knows exactly where she going (without looking at signs, down hallways, or reading door labels) and even greeting people she sees with a friendly *Hi, how are you doing?*
- *Use evasion and diversion.* When challenged, threat agents might evade a question by giving a vague or irrelevant answer. They could also feign innocence or confusion, or keep denying allegations, until the victim eventually believes his suspicions are wrong. Sometimes a threat agent can resort to anger and cause the victim to drop the challenge. *Who are you to ask that? Connect me with your supervisor immediately!*
- *Make them laugh.* Humor is an excellent tool to put people at ease and to develop a sense of trust. *I can't believe I left my badge in my office again! You know, some mistakes are too much fun to make only once!*

Social engineering psychological approaches often involve impersonation, phishing, redirection, spam, hoaxes, and watering hole attacks.

Impersonation Social engineering **impersonation** (also called **identity fraud**) is masquerading as a real or fictitious character and then playing the role of that person with a victim. For example, an attacker could impersonate a help desk support technician who calls the victim, pretends that there is a problem with the network, and asks for her username and password to reset the account. Sometimes the goal of the impersonation is to obtain private information (**pretexting**).

**CAUTION**

Common roles that are often impersonated include a repair person, an IT support technician, a manager, or a trusted third party. Often attackers impersonate individuals whose roles are authoritative because victims generally resist saying "no" to anyone in power. Users should exercise caution when receiving a phone call or email from these types of people asking for something suspicious.

To impersonate real people, the threat actor must know as much about them as possible to appear genuine. This type of **reconnaissance** is called **credential harvesting** and is typically carried out by Internet and social media searches.

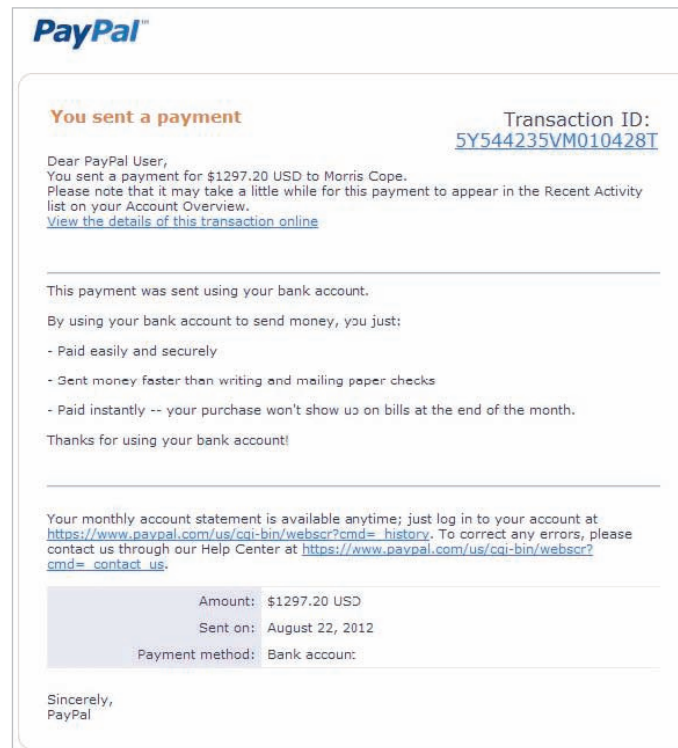
Phishing One of the most common forms of social engineering is phishing. **Phishing** is sending an email message or displaying a web announcement that falsely claims to be from a legitimate enterprise in an attempt to trick the user

into surrendering private information or taking action. Users are asked to respond to an email message or are directed to a website where they are requested to update personal information, such as passwords, credit card numbers, Social Security numbers, bank account numbers, or other information. However, the email or website is actually an imposter site set up to steal the information the user enters. Users may also receive a fictitious overdue invoice that demands immediate payment and, in haste, make the payment (called an **invoice scam**).

Whereas at one time phishing messages were easy to spot due to misspelled words and obvious counterfeit images, that is no longer the case. In fact, one reason that phishing is so successful today is that the emails and the fake websites are difficult to distinguish from legitimate ones: logos, color schemes, and wording seem to be almost identical. Figure 1-4 illustrates an actual phishing email message that looks like it came from a legitimate source.

NOTE 10

The word *phishing* is a variation on the word “fishing,” to reflect the idea that bait is thrown out knowing that while most will ignore it, some will bite.



Source: Email message sent to Dr. Mark Revels

Figure 1-4 Phishing email message

CAUTION

Phishing is also used to validate email addresses. A phishing email message can display an image retrieved from a website and requested when the user opens the email message. A unique code links the image to the recipient's email address, which then tells the phisher that the email address is active and valid. This is the reason most email today does not automatically display images received in emails. Users should be cautious in displaying images in email messages.

The following are several variations on phishing attacks:

- **Spear phishing.** Whereas phishing involves sending millions of generic email messages to users, **spear phishing** targets specific users. The emails used in spear phishing are customized to the recipients, including their names and personal information, to make the message appear legitimate.
- **Whaling.** One type of spear phishing is **whaling**. Instead of going after the “smaller fish,” whaling targets the “big fish”—namely, wealthy individuals or senior executives within a business who typically have large sums of money in a bank account that an attacker could access if the attack is successful. By focusing on this smaller

group, the attacker can invest more time in the attack and finely tune the message to achieve the highest likelihood of success.

- **Vishing.** Instead of using email to contact the potential victim, attackers can use phone calls. Known as **vishing** (voice phishing), an attacker calls a victim who, upon answering, hears a recorded message that pretends to be from the user's bank stating that her credit card has experienced fraudulent activity or that her bank account has had unusual activity. The victim is instructed to call a specific phone number immediately (which has been set up by the attacker). When the victim calls, it is answered by automated instructions telling her to enter her credit card number, bank account number, Social Security number, or other information on the phone's keypad.
- **Smishing.** A variation on vishing uses short message service (SMS) text messages and callback recorded phone messages. This is known as **smishing**. The threat actors first send a text message to a user's cell phone that pretends to come from their bank saying that their account has been broken into or their credit card number has been stolen. Along with the text message is a callback telephone number the customer is instructed to call immediately. That phone number plays a recording telling the customer to enter their Social Security number or credit card number for verification. The attackers then simply capture the information the user enters.

Phishing continues to be a primary weapon used by threat actors. Phishing is considered to be one of the largest and most consequential cyber threats facing both businesses and consumers. During the third quarter of 2019, phishing attacks increased by 46 percent from the previous quarter and almost doubled the number recorded during the fourth quarter of the previous year. One nation saw a 232 percent increase in phishing during 2019.¹³ It is estimated that these trends will continue.



CAUTION

Although most web browsers automatically block known phishing websites, because so many sites are appearing so rapidly, it is difficult for the browsers to stay up to date. Users should remain constantly vigilant to guard against phishing attacks.

NOTE 11

The cost of typo squatting is significant because of frequent misspellings. In one month, the typo squatting site *goggle.com* received almost 825,000 unique visitors. It is estimated that typo squatting costs the 250 top websites \$285 million annually in lost sales and other expenses.¹⁴

NOTE 12

An increasing number of registered attacker domains are the result of bitsquatting, such as *aeazon.com* (for *amazon.com*) and *microsmft.com* (for *microsoft.com*). Security researchers found that 20 percent of a sample of 433 registered attacker domains were the result of bitsquatting.¹⁵

Redirection If threat actors cannot trick a user to visit a malicious website through phishing, they can use other tactics to redirect the user.

What happens if a user makes a typing error when entering a uniform resource locator (URL) address in a web browser, such as typing *goggle.com* (a misspelling) or *google.net* (incorrect domain) instead of the correct *google.com*? In the past, an error message like *HTTP Error 404 Not Found* would appear. However, today the user is often directed to a fake lookalike site filled with ads for which the attacker receives money for traffic generated to the site. These fake sites exist because attackers purchase the domain names of sites that are spelled similarly to actual sites. This is called **typo squatting**. A well-known site such as *google.com* may have to deal with more than 1,000 typo squatting domains.

Enterprises have tried to preempt typo squatting by registering the domain names of close spellings of their website. At one time, top-level domains (TLDs) were limited to .com, .org, .net, .int, .edu, .gov, and .mil, so it was fairly easy to register close-sounding domain names. However, today there are more than 1,200 generic TLDs (gTLDs), such as .museum, .office, .global, and .school. Organizations must now attempt to register many sites that are a variation of their registered domain name.

In addition to registering names similar to the actual names (like *goggle.com* for *google.com*), threat actors are registering domain names that are *one bit* different. The billions of devices that are part of the Internet have multiple instances of a domain name in a domain name server (DNS) memory at any time, increasing the likelihood of a RAM memory error that involves a bit being "flipped." Figure 1-5 illustrates that the change of one bit in the letter *g* (01100111) results in the change of the entire character from *g* to *f*. In this example, a threat agent would register the domain *foo.gl* as a variation of the actual *goo.gl*.

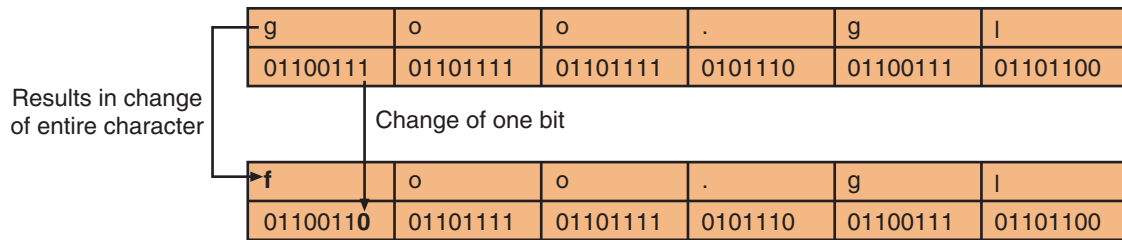


Figure 1-5 Character change by bit flipping

Another redirection technique is **pharming**. Pharming attempts to exploit how a URL such as www.cengage.com is converted into its corresponding IP address 69.32.308.75. A threat actor may install malware on a user's computer that redirects traffic away from its intended target to a fake website instead. Another technique is to infect a DNS that would direct multiple users to inadvertently visit the fake site.

Spam **Spam** is unsolicited email that is sent to a large number of recipients. Users receive so many spam messages because sending spam is lucrative. It costs spammers very little to send millions of spam email messages. Almost all spam is sent from botnets, and a spammer who does not own his own botnet can lease time from other attackers (\$40 per hour) to use a botnet of up to 100,000 infected computers to launch a spam attack. Even if spammers receive only a small percentage of responses, they still make a large profit. For example, if a spammer sent spam to 6 million users for a product with a sale price of \$50 that cost only \$5 to make, and if only 0.001 percent of the recipients responded and bought the product (a typical response rate), the spammer would still make more than \$270,000 in profit.

Text-based spam messages that include words such as *Viagra* or *investments* can easily be trapped by filters that look for these words and block the email. Because of the increased use of these filters, spammers have turned to *image spam*, which uses graphical images of text in order to circumvent text-based filters. Image spam cannot be filtered based on the textual content of the message because it appears as an image instead of text. These spam messages often include nonsense text so that it appears the email message is legitimate (an email with no text can prompt the spam filter to block it). Figure 1-6 shows an example of an image spam.

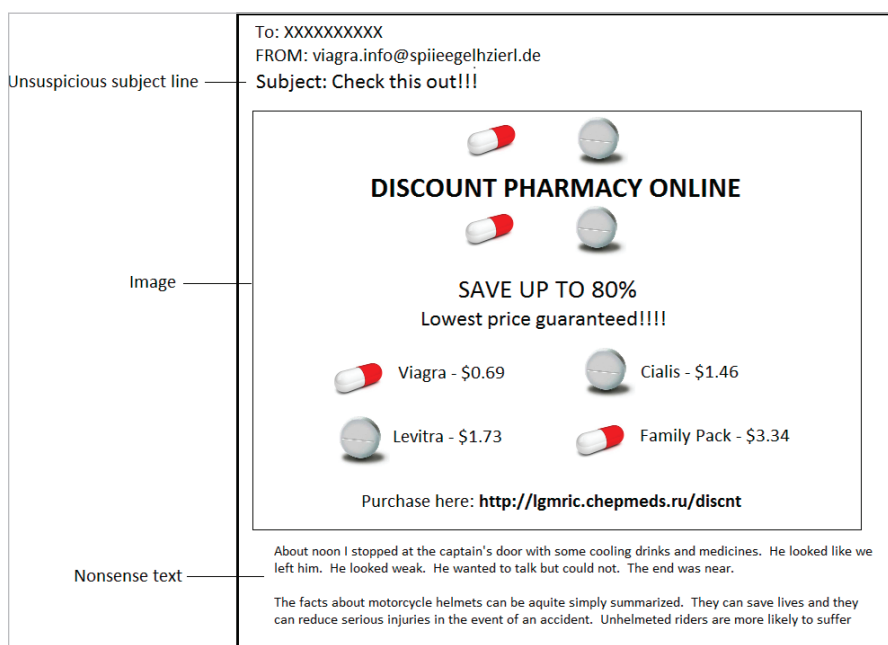


Figure 1-6 Image spam

Spim is spam delivered through instant messaging (IM) instead of email. For threat actors, spim can have even more impact than spam. The immediacy of instant messages makes users more likely to reflexively click embedded links in a spim. Furthermore, because spim may bypass some antimalware defenses, spim can more easily distribute malware. As antispam measures for email are more widely implemented, more spammers may be inclined to migrate to sending spim.

Beyond being annoying and interfering with work productivity as users spend time reading and deleting spam messages, spam and spim can be security vulnerabilities. This is because they can be used to distribute malware. Messages sent with attachments that contain malware are common means by which threat actors distribute their malware today.

Hoaxes Threat agents can use hoaxes as a first step in an attack. A **hoax** is a false warning, often contained in an email message claiming to come from the IT department. The hoax purports that there is a “deadly virus” circulating through the Internet and that the recipient should erase specific files or change security configurations and then forward the message to other users. However, changing configurations allows an attacker to compromise the system. And erasing files may make the computer unstable, prompting the victim to call the phone number in the hoax email message for help, which is actually the phone number of the attacker.

Watering Hole Attack In the natural world, similar types of animals are known to congregate around a pool of water for refreshment. In a similar manner, a **watering hole attack** is directed toward a smaller group of specific individuals, such as the major executives working for a manufacturing company. These executives all tend to visit a common website, such as that of a parts supplier to the manufacturer. An attacker who wants to target this group of executives tries to determine the common website that they frequent and then infects it with malware that will make its way onto the group’s computers.

Physical Procedures

While some social engineering attacks rely on psychological manipulation, other attacks rely on physical acts. These attacks take advantage of user actions that can result in compromised security. Three of the most common physical procedures are dumpster diving, tailgating, and shoulder surfing.

Dumpster Diving **Dumpster diving** involves digging through trash receptacles to find information that can be useful in an attack. Table 1-5 lists the different items that can be retrieved—many of which appear to be useless—and how they can be used.

Table 1-5 Dumpster diving items and their usefulness

Item retrieved	Why useful
Calendars	A calendar can reveal which employees are out of town at a particular time.
Inexpensive computer hardware, such as USB flash drives or portal hard drives	These devices are often improperly disposed of and might contain valuable information.
Memos	Seemingly unimportant memos can often provide small bits of useful information for an attacker who is building an impersonation.
Organizational charts	These identify individuals within the organization who are in positions of authority.
Phone directories	A phone directory can provide the names and telephone numbers of individuals in the organization to target or impersonate.
Policy manuals	These may reveal the true level of security within the organization.
System manuals	A system manual can tell an attacker the type of computer system that is being used so that other research can be conducted to pinpoint vulnerabilities.

An electronic variation of physical dumpster diving is to use the Google search engine to look for documents and data posted online that can be used in an attack. This is called *Google dorking*, and it uses advanced Google search techniques to look for information that unsuspecting victims have carelessly posted on the web.

For example, to find on the web any Microsoft Excel spreadsheets (.xlsx) that contain the column heading "SSN" (Social Security number), the Google search term *intext:"SSN" filetype:xlsx* can be used, or to find any Microsoft Word documents (.docx) that contained the word "passwords" as part of the title, the Google search term *allintitle:"passwords" filetype:docx* is used.

Tailgating Organizations can invest tens of thousands of dollars to install specialized doors that permit access only to authorized users who possess a special card or who can enter a specific code. These automated access control systems are designed to restrict entry into an area. However, a weakness of these systems is that they cannot always control *how many* people enter the building when access is allowed; once an authorized person opens the door, one or more individuals can follow behind and also enter. This is known as **tailgating**.

The following are several ways tailgating can occur:

- A tailgater waits at the end of the sidewalk until an authorized user opens the door. She then calls out to him to "Please hold the door!" as she hurries to enter. In most cases, good etiquette wins out over good security practices, and the door is held open for the tailgater.
- A tailgater waits near the outside of the door and then quickly enters once the authorized employee leaves the area. This technique is used most commonly during weekends and at nights, where the actions of the more overt tailgater would be suspicious.
- A tailgater stands outside the door and waits until an employee exits the building. He then slips behind the person as he is walking away and grabs the door just before it closes to gain access to the building.
- An employee conspires with an unauthorized person to allow him to walk in with him through the open door (called *piggybacking*).

Shoulder Surfing If an attacker cannot enter a building as a tailgater without raising suspicion, an alternative is to watch an individual entering the security code on a keypad. Known as **shoulder surfing**, this technique can be used in any setting that allows an attacker to casually observe someone entering secret information, such as the security codes on a door keypad. Attackers are also using webcams and smartphone cameras to "shoulder surf" users of ATM machines to record keypad entries.



CAUTION

A defense against shoulder surfing is an application that uses the computer's web cam to watch if anyone nearby is looking at the computer screen. If someone is detected, the user can be alerted with a popup window message or the screen will automatically blur so that it cannot be read.

Impacts of Attacks

A successful attack always results in several negative impacts. These impacts can be classified as data impacts and effects on the organization.

Data Impacts

Whereas the goal of some attacks may be harm to a system, such as manipulating an industrial control system to shut down a water filtration facility, most attacks focus on data as the primary target. The consequences of a successful attack on data are listed in Table 1-6.

Effects on the Enterprise

A successful attack can also have grave consequences for an enterprise. First, the attack may make systems inaccessible (**availability loss**). This results in lost productivity, which can affect the normal tasks for generating income (**financial loss**).

NOTE 13

Google dorking is from a slang term that originally was used to refer to someone who is not considered intelligent (a *dork*) and later came to refer to uncovering security vulnerabilities that are the result of the actions of such a person.

Table 1-6 Consequences of data attack

Impact	Description	Example
Data loss	Destroying data so that it cannot be recovered	Maliciously erasing patient data used for cancer research
Data exfiltration	Stealing data to distribute it to other parties	Taking a list of current customers and selling it to a competitor
Data breach	Stealing data to disclose it in an unauthorized fashion	Stealing credit card numbers to sell to other threat actors
Identity theft	Taking personally identifiable information to impersonate someone	Stealing a Social Security number to secure a bank loan in the victim's name

One of the most devastating effects is on the public perception of the enterprise (**reputation**). If an organization is the victim of an attack that steals customer data, the public blames the organization and forms a serious negative impression. Many current customers will become disgruntled at the perceived lack of security at the organization and move their business to a competitor.

TWO RIGHTS & A WRONG

1. Spear phishing targets specific users.
2. "I'm the CEO calling" is an example of the psychological principle of authority.
3. The goal of impersonation is often prepending, which is obtaining private information.

See Appendix B for the answer.



VM LAB

You're now ready to complete the live, virtual machine labs for this module. The labs can be found in each module in the MindTap.

SUMMARY

- Attacks against information security have grown astronomically in recent years. Eighty percent of organizations have experienced at least one successful attack in a single year, with many organizations suffering multiple successful attacks annually. Compounding the problem is a serious shortfall of skilled security professionals.
- The information security workforce is usually divided into two broad categories. Information security managerial personnel administer and manage plans, policies, and people, while information security technical personnel are concerned with designing, configuring, installing, and maintaining technical security equipment.
- The CompTIA Security+ certification is a vendor-neutral credential that requires passing the current certification exam, SY0-601. A successful candidate has the knowledge and skills required to identify attacks, threats, and vulnerabilities; design a strong security architecture; implement security controls, be knowledgeable of security operations and incident response; and be well versed in governance, risk, and compliance requirements.
- Security can be defined as the necessary steps to protect from harm. The relationship between security and convenience is inversely proportional: as security is increased, convenience is decreased. Information security protects the integrity, confidentiality, and availability of information through products, people, and procedures on the devices that store, manipulate, and transmit the information.
- The threat actors, or individuals behind computer attacks, fall into several categories and exhibit different attributes. Some groups have a high level of power and complexity with a massive network of resources,

while others work alone and have minimal skills and no resources. Some groups have deep resources and funding while others have none. Certain threat actors are internal and work within the enterprise, and others are strictly outside the organization. The intent and motivation, or the reasons for the attacks, vary widely.

- Script kiddies do their work by downloading automated attack software from websites and then using it to break into computers. Hacktivists are strongly motivated by their ideology and often attack to make a political statement. State actors are employed by governments as state-sponsored attackers for launching computer attacks against foes. Other threat actors include competitors, criminal syndicates, shadow IT, brokers, and cyberterrorists.
- Cybersecurity vulnerabilities are often categorized into five broad categories: platforms, configurations, third parties, patches, and zero-day vulnerabilities. Several vulnerabilities are the result of the platform being used. Legacy or outdated platforms have not been updated and are prime targets for attacks. On-premises platforms are located within the physical confines of an enterprise, which are usually consolidated in the company's data center. Due to the rapid provisioning of resources, on-premises platforms are often not adequately configured for security. Cloud platforms are proven to have significant vulnerabilities. These vulnerabilities are most often based on misconfigurations by company personnel responsible for securing the cloud platform.
- Modern hardware and software platforms provide a wide array of features and security settings, and these must be properly configured to repel attacks. Unfortunately, the configuration settings are not always properly implemented, resulting in weak configurations. Many enterprises also use IT-related third parties due to their elevated level of expertise. Almost all third parties require access to the organization's computer network. However, often the organization's systems are not compatible with the third party's systems and require work-arounds, which can create vulnerabilities. A security patch is an officially released software security update intended to repair a vulnerability. However, as important as patches are, they can create vulnerabilities. A zero-day vulnerability has no advance warning because there has been no previous knowledge of the vulnerability.
- An attack vector is a pathway or avenue used by a threat actor to penetrate a system. Although there are many specific types of attacks, vectors can be grouped into general categories. These include email, wireless, removable media, direct access, social media, supply chain, and cloud.
- Social engineering is a means of eliciting information (gathering data) by relying on the weaknesses of individuals. Information elicitation may be the goal of the attack, or the information may be used for other attacks. Many social engineering attacks rely on psychology, which involves taking a mental and emotional approach—rather than a physical approach—to gathering data. At its core, social engineering relies on an attacker's clever manipulation of human nature to persuade the victim to provide information or take actions. Social engineering psychological approaches often involve impersonation, phishing, redirection, spam, hoaxes, and watering hole attacks. Some social engineering attacks rely on physical acts. These attacks take advantage of user actions that can result in compromised security. Three of the most common physical procedures are dumpster diving, tailgating, and shoulder surfing.
- A successful attack always results in several negative impacts. Most attacks focus on data as the primary target. The consequences of a successful attack on data are data loss, data exfiltration, data breach, and identity theft. A successful attack can also have significant consequences for an enterprise. Systems may be rendered inaccessible, which results in lost productivity and impacts the normal tasks for generating income. One of the most devastating effects is on the public perception of the enterprise, or its reputation. An organization that is the victim of an attack in which customer data is stolen faces a serious negative impression in the eye of the public.

Key Terms

advanced persistent threat (APT)
attack vector
attributes
authority
availability loss
black hat hackers
cloud platforms

competitors
consensus
credential harvesting
criminal syndicates
data breach
data exfiltration
data loss

data storage
default settings
direct access
dumpster diving
eliciting information
errors
external

familiarity	level of capability/sophistication	spear phishing
financial loss	on-premises platform	spim
firmware	open permissions	state actors
gray hat hackers	open ports and services	supply chain
hacker	outsourced code development	system integration
hacktivists	patch	tailgating
hoax	pharming	third parties
hybrid warfare influence campaign	phishing	threat actor
identity fraud (also called impersonation)	prepending	trust
identity theft	pretexting	typo squatting
impersonation (also called identity fraud)	reconnaissance	unsecure protocols
influence campaigns	reputation	unsecured root accounts
insider threat	resources and funding	urgency
intent/motivation	scarcity	vendor management
internal	script kiddies	vishing
intimidation	shadow IT	watering hole attack
invoice scam	shoulder surfing	weak configurations
lack of vendor support	smishing	weak encryption
legacy platform	social engineering	whaling
	social media influence campaign	white hat hackers
	spam	zero day

Review Questions

- After Bella earned her security certification, she was offered a promotion. As she reviewed the job responsibilities, she saw that in this position she will report to the CISO and supervise a group of security technicians. Which of these generally recognized security positions has she been offered?
 - Security administrator
 - Security technician
 - Security officer
 - Security manager
- Which of the following is false about the CompTIA Security+ certification?
 - Security+ is one of the most widely acclaimed security certifications.
 - Security+ is internationally recognized as validating a foundation level of security skills and knowledge.
 - The Security+ certification is a vendor-neutral credential.
 - Professionals who hold the Security+ certification earn about the same or slightly less than security professionals who have not achieved this certification.
- Which of the following is true regarding the relationship between security and convenience?
 - Security and convenience are inversely proportional.
 - Security and convenience have no relationship.
 - Security is less important than convenience.
 - Security and convenience are equal in importance.
- Which of the following of the CIA Triad ensures that information is correct, and no unauthorized person has altered it?
 - Confidentiality
 - Integrity
 - Availability
 - Assurance
- Which of the following is *not* used to describe those who attack computer systems?
 - Threat actor
 - Hacker
 - Malicious agent
 - Attacker
- Which of the following is *not* true regarding security?
 - Security is a goal.
 - Security includes the necessary steps to protect from harm.
 - Security is a process.
 - Security is a war that must be won at all costs.
- Luna is reading a book about the history of cybercrime. She read that the very first cyberattacks were mainly for what purpose?
 - Fortune
 - Fame

- c. Financial gain
 - d. Personal security
8. Which of the following ensures that only authorized parties can view protected information?
- a. Authorization
 - b. Confidentiality
 - c. Availability
 - d. Integrity
9. Which type of hacker will probe a system for weaknesses and then privately provide that information back to the organization?
- a. Black hat hackers
 - b. White hat hackers
 - c. Gray hat hackers
 - d. Red hat hackers
10. Complete this definition of information security: *That which protects the integrity, confidentiality, and availability of information _____.*
- a. *on electronic digital devices and limited analog devices that can connect via the Internet or through a local area network.*
 - b. *through a long-term process that results in ultimate security.*
 - c. *using both open-sourced as well as supplier-sourced hardware and software that interacts appropriately with limited resources.*
 - d. *through products, people, and procedures on the devices that store, manipulate, and transmit the information.*
11. Which of the following groups have the lowest level of technical knowledge?
- a. Script kiddies
 - b. Hacktivists
 - c. State actors
 - d. Insiders
12. Which of the following groups use advanced persistent threats?
- a. Brokers
 - b. Criminal syndicates
 - c. Shadow IT
 - d. State actors
13. Which of the following is *not* a reason a legacy platform has not been updated?
- a. Limited hardware capacity
 - b. An application only operates on a specific OS version
 - c. Neglect
 - d. No compelling reason for any updates
14. How do vendors decide which should be the default settings on a system?
- a. Those that are the most secure are always the default settings.
 - b. There is no reason specific default settings are chosen.
 - c. Those settings that provide the means by which the user can immediately begin to use the product.
 - d. The default settings are always mandated by industry standards.
15. Which tool is most commonly associated with state actors?
- a. Closed-Source Resistant and Recurrent Malware (CSRRM)
 - b. advanced persistent threat (APT)
 - c. Unlimited Harvest and Secure Attack (UHSA)
 - d. Network Spider and Worm Threat (NSAWT)
16. What is the term used to describe the connectivity between an organization and a third party?
- a. System integration
 - b. Platform support
 - c. Resource migration
 - d. Network layering
17. What is an objective of state-sponsored attackers?
- a. To right a perceived wrong
 - b. To amass fortune over of fame
 - c. To spy on citizens
 - d. To sell vulnerabilities to the highest bidder
18. Which of the following is *not* an issue with patching?
- a. Difficulty patching firmware
 - b. Few patches exist for application software
 - c. Delays in patching OSs
 - d. Patches address zero-day vulnerabilities
19. Which of the following is *not* a recognized attack vector?
- a. Supply chain
 - b. Social media
 - c. On-prem
 - d. Email
20. What is the category of threat actors that sell their knowledge of vulnerabilities to other attackers or governments?
- a. Cyberterrorists
 - b. Competitors
 - c. Brokers
 - d. Resource managers

Hands-On Projects

Project 1-1: Examine Data Breaches—Visual

Time Required: 15 minutes

Objective: Explain the security concerns associated with various types of vulnerabilities.

Description: In this project, you use a visual format to view the biggest data breaches resulting in stolen information.

1. Open your web browser and enter the URL **www.informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/** (If you are no longer able to access the site through this web address, use a search engine to search for “Information Is Beautiful World’s Biggest Data Breaches & Hacks.”)
2. This site will display a visual graphic of the data breaches, as shown in Figure 1-7.

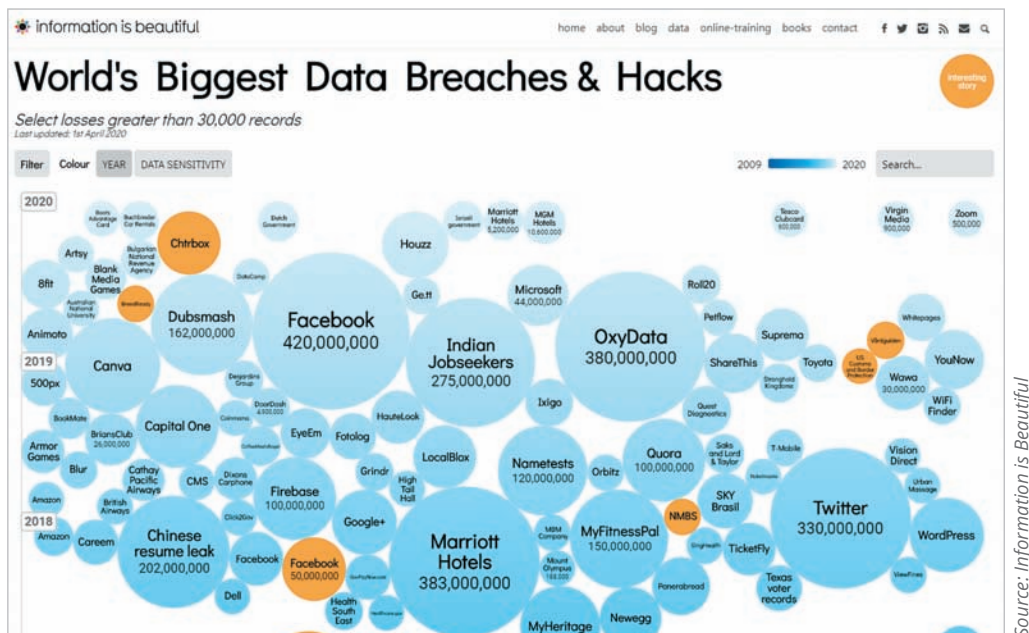


Figure 1-7 World's biggest data breaches & hacks webpage

3. Scroll down the page to view the data breaches by year. Note that the size of the breach is indicated by the size of the bubble.
4. Scroll back up to the top.
5. Hover over several of the bubbles to read a quick story of the breach.
6. Note the color of the bubbles that have an “Interesting Story.” Click one of the bubbles and read the story. When finished, close only the interesting story tab in your browser.
7. Click the **Data Sensitivity** button on the World’s Biggest Data Breaches & Hacks page. Note the color legend from Low to High that indicates how sensitive the data was.
8. Click the **Year** button to return to the original screen.
9. Click the **Filter** button to display the filter menu.
10. Under Sector, click **healthcare** to view those breaches related to the healthcare industry.
11. Click one of the bubbles and read the story.
12. Click **Reset** in the filter menu.
13. Select the sector **financial**.
14. Select the method **poor security**.
15. Click one of the bubbles and read the story.
16. Create your own filters to view different types of breaches. Does this graphic convey a compelling story of data breaches?
17. How does this visualization help you with the understanding of threats?
18. Close all windows.

Project 1-2: Scan for Malware Using the Microsoft Safety Scanner

Time Required: 15 minutes

Objective: Given a scenario, analyze potential indicators to determine the type of attack.

Description: In this project, you download and run the Microsoft Safety Scanner to determine if there is any malware on the computer.

1. Determine which system type of Windows you are running. Click **Start**, **Settings**, **System**, and then **About**. Look under System type for the description.
2. Open your web browser and enter the URL *docs.microsoft.com/en-us/windows/security/threat-protection/intelligence/safety-scanner-download* (If you are no longer able to access the site through the URL, use a search engine to search for "Microsoft Safety Scanner.")
3. Select either **Download Microsoft Safety Scanner (32-bit)** or **Download Microsoft Safety Scanner (64-bit)**, depending upon which system type of Windows you are running.
4. When the **MSERT.exe** program finishes downloading, launch this program by double-clicking it.
5. If a warning dialog box appears, click **Run anyway**.
6. If a User Account Control dialog box appears, click **Yes**.
7. Click the check box to accept the license terms for this software. Click **Next**.
8. Click **Next**.
9. Select **Quick scan** if necessary.
10. Click **Next**.
11. Depending on your computer, this scan may take several minutes. Analyze the results of the scan to determine if it found any malicious software in your computer.
12. If you have problems, you can click **View detailed results of the scan**. After reviewing the results, click **OK**. If you do not find any problems, click **Finish**.
13. If any malicious software was found on your computer, run the scan again and select **Full scan**. After the scan is complete, click **Finish** to close the dialog box.
14. Close all windows.

Project 1-3: Configure Microsoft Windows Sandbox

Time Required: 15 minutes

Objective: Given a scenario, implement host or application security solutions.

Description: A *sandbox* is an isolated virtual machine: anything run within a sandbox will impact only the virtual machine and not the underlying computer. The Microsoft Windows Sandbox first became available in Windows 10 Version 1903 released in 2019, and additional features have been added with recent Windows 10 updates to provide even more control.

NOTE 14

Although separate programs can perform a sandbox function, the Windows Sandbox has the advantages of being included as part of Windows, so nothing has to be downloaded and installed. It relies on the Microsoft hypervisor to run a separate kernel that isolates the Windows Sandbox from the host. This makes it more efficient since it can take advantage of the Windows integrated kernel scheduler, smart memory management, and a virtual GPU. Once you close the Windows Sandbox, nothing remains on your computer; when you launch Windows Sandbox again, it is as clean as new.

In this project you will configure the Windows Sandbox to use with this book.



CAUTION

You must be running Windows 10 Professional, Enterprise, or Education (not Home) Version 1903 or higher. To determine which version you are running, click Settings, then System, and then About. If you are not using the correct version, skip to the next project to create a different virtual machine.

1. First check if your system has virtualization turned on. Right-click the taskbar (at the bottom of the screen) and select **Task Manager**.
2. Click the **Performance** tab.
3. Under Virtualization, it must say "Enabled." If it says "Disabled," you will need to reboot and enter your BIOS or UEFI and turn on virtualization.

NOTE 15

With older BIOS, you may also need to disable other settings, such as Hyper-threading.

4. Now enable Windows Sandbox. In the Windows search box on the taskbar, enter **Windows Features** to open the Windows Features window.
5. Click the **Windows Sandbox** check box to turn on this feature.
6. To launch Windows Sandbox, click **Start**, and scroll down to Windows Sandbox, and then click **Windows Sandbox**. A protected virtual machine sandbox that looks like another Windows instance will start, as shown in Figure 1-8.

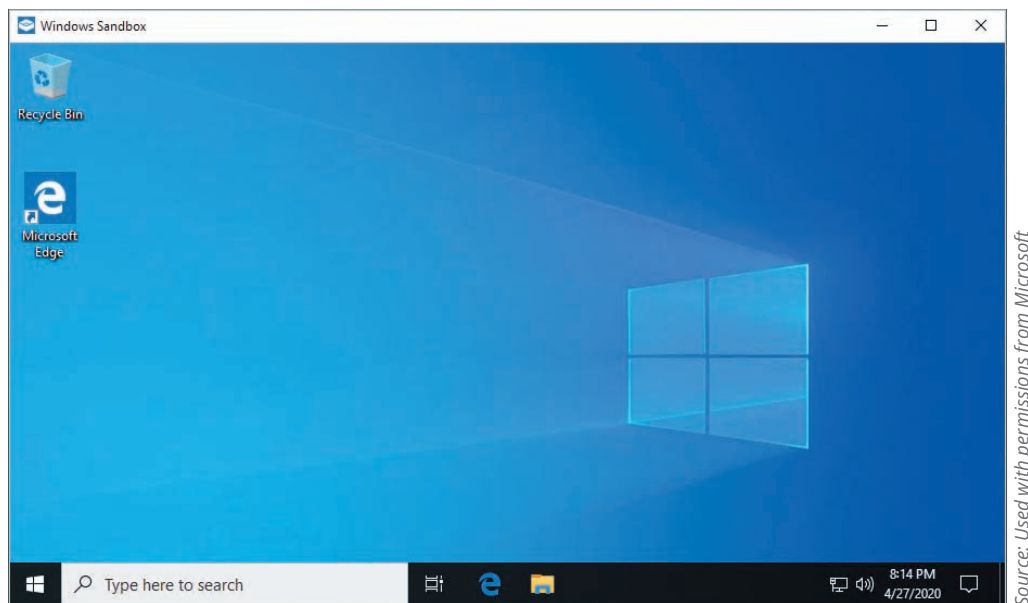


Figure 1-8 Windows sandbox

7. Explore the settings and default applications that come with the Windows Sandbox.
8. You can download a program through the Microsoft Edge application in Windows Sandbox. (Edge is included within Windows Sandbox along with a handful of other Windows applications, including access to OneDrive.) Open Edge and go to **www.google.com** to download and install the Google Chrome browser in the Windows Sandbox.

NOTE 16

You can also copy an executable file from your normal Windows environment and then paste it to the Windows Sandbox desktop to launch it.

9. After the installation is complete, close the Windows Sandbox.
10. Now relaunch the Windows Sandbox. What happened to Google Chrome? Why?
11. Close all windows.

Project 1-4: Create a Virtual Machine of Windows 10 for Security Testing—Part 1

Time Required: 25 minutes

Objective: Given a scenario, implement host or application security solutions.

Description: If you were unable to install the Windows Sandbox in Project 1-3, a different virtual machine can be created in which new applications can be installed or configuration settings changed without affecting the base computer. In a virtual machine environment, the “host” computer runs a “guest” operating system. Security programs and testing can be conducted within this guest operating system without affecting the regular host operating system. In this project, you create a virtual machine using Oracle VirtualBox software.

1. Open a web browser and enter the URL **www.virtualbox.org** (If you are no longer able to access the site through this web address, use a search engine to search for “Oracle VirtualBox download.”)
2. Click **Downloads** (or a similar link or button).
3. Under VirtualBox binaries, select the latest version of VirtualBox to download for your specific host operating system. For example, if you are running Windows, select the version for “Windows hosts.”
4. Under VirtualBox x.x.x Oracle VM VirtualBox Extension Pack, click **All supported platforms** to download the extension package.
5. Navigate to the folder that contains the downloads and launch the VirtualBox installation program **VirtualBox-xxx-nnnnn-hhh.exe**.
6. Accept the default configurations from the installation wizard to install the program.
7. If you are asked “Would you like to install this device software?” on one or more occasions, click **Install**.
8. When completed, click **Finish** to launch VirtualBox.
9. Now install the VirtualBox extensions. Click **File** and then click **Preferences**.
10. Click **Extensions**.
11. Click the **Add a package** icon on the right side of the screen.
12. Navigate to the folder that contains the extension pack downloaded earlier to select that file. Click **Open**.
13. Click **Install**. Follow the necessary steps to complete the default installation.
14. Remain in VirtualBox for the next project to configure VirtualBox and install the guest operating system.

Project 1-5: Create a Virtual Machine of Windows 10 for Security Testing—Part 2

Time Required: 20 minutes

Objective: Given a scenario, implement host or application security solutions.

Description: After installing VirtualBox, the next step is to create the guest operating system. For this project, Windows 10 will be installed. Different options are available for obtaining a copy of Windows:

- A retail version of the software can be purchased.
 - If you or your school is a member of the Microsoft Azure Dev Tools for Teaching program, the operating system software and a license can be downloaded. See your instructor or lab supervisor for more information.
 - A 90-day evaluation copy can be downloaded and installed from the Microsoft TechNet Evaluation Center (**www.microsoft.com/en-US/evalcenter/evaluate-windows-10-enterprise**).
1. Obtain the ISO image of Windows 10 using one of the preceding options and save it on the hard drive of the computer.
 2. Launch VirtualBox.
 3. Click **New**.
 4. In the Name: box, enter **Windows 10** as the name of the virtual machine.
 5. Be sure that the Type: box displays **Microsoft Windows** and the Version: box changes to **Windows 10 (xx-bit)**. Click **Next**.
 6. Under Memory size, accept the recommended size or increase the allocation if you have sufficient RAM on your computer. Click **Next**.
 7. Under Hard disk, accept **Create a virtual hard drive now**. Click **Create**.
 8. Under Hard drive file type, accept the default **VID (VirtualBox Disk Image)**. Click **Next**.
 9. Under Storage on physical hard drive, accept the default **Dynamically allocated**. Click **Next**.
 10. Under File location and size, accept **Windows 10**. Click **Create**.

11. Now the configuration settings for the virtual machine are set. Next you will load the Windows 10 ISO image. Click **Settings**.
12. In the left pane, click **Storage**.
13. Under Controller: click **Empty**.
14. In the right page under Attributes, click the icon of the optical disc.
15. Click **Choose Virtual Optical Disk File**.
16. Navigate to the location of the Windows 10 ISO file and click **Open**.
17. Click **OK**.
18. Click **Start** to launch the Windows 10 ISO.
19. Follow the Windows 10 installation wizard to complete the installation.
20. To close the Windows 10 guest operating system in VirtualBox, click **File** and then click **Exit**.
21. Close all windows.

Case Projects

Case Project 1-1: Personal Attack Experiences

What type of computer attack have you (or a friend or another student) experienced? When did it happen? What type of computer or device was involved? What type of damage did it inflict? What had to be done to clean up following the attack? How was the computer fixed after the attack? What could have prevented it? List the reason or reasons you think that the attack was successful. Write a one-page paper about these experiences.

Case Project 1-2: Security Podcasts or Video Series

Many security vendors and security researchers now post weekly audio podcasts or video series on YouTube on security topics. Locate two different podcasts and two different video series about computer security. Listen and view one episode of each. Then write a summary of what was discussed and a critique of the podcasts and videos. Were they beneficial to you? Were they accurate? Would you recommend them to someone else? Write a one-page paper on your research.

Case Project 1-3: Phishing Simulators

Search the Internet for three different phishing simulators. Take the phishing challenge on each simulator to determine if you can identify the phishing attacks. Then create a table that lists the features of the phishing simulators, their ease of use, and how accurate you think they were. Would these simulators be helpful in training users about phishing? Write a one-paragraph summary along with your table.

Case Project 1-4: Sources of Security Information

The following is a partial overall list of some of the sources for security information:

- Security content (online or printed articles that deal specifically with unbiased security content)
- Consumer content (general consumer-based magazines or broadcasts not devoted to security but occasionally carry user security tips)
- Vendor content (material from security vendors who sell security services, hardware, or software)
- Security experts (IT staff recommendations or newsletters)
- Direct instruction (college classes or a workshop conducted by a local computer vendor)
- Friends and family
- Personal experience

Create a table with each of these sources and columns that list Advantages, Disadvantages, Example, and Rating. Use the Internet to complete the entire table. The Rating column is a listing from 1 to 7 (with 1 being the highest) of how useful each of these sources is in your opinion. Compare your table with other learners.

Case Project 1-5: Information Security Community Site Activity

The Information Security Community Site is an online companion to this textbook. It contains a wide variety of tools, information, discussion boards, and other features to assist learners. In order to gain the most benefit from the site, you will need to set up a free account.

Go to **community.cengage.com/infosec2**. Click **Join the Community**. On the Join the Community page, enter the requested information to create your account.

NOTE 17

Your instructor may have a specific naming convention that you should use, such as the name of your course followed by your initials. Check with your instructor before creating your sign-in name.

Explore the various features of the Information Security Community Site and become familiar with it. Visit the blog section and read the blog postings to learn about some of the latest events in IT security.

Case Project 1-6 North Ridge Security

North Ridge Security provides security consulting and assurance services to over 500 clients in more than 20 states and a wide range of enterprises. A new initiative at North Ridge is for each of its seven regional offices to provide internships to students who are in their final year of the security degree program at the local college.

As part of National Cybersecurity Awareness Month, North Ridge is visiting local high schools to talk about careers in cybersecurity. You have been asked to present an introductory session on the need for cybersecurity workers, the types of jobs that are available, what a cybersecurity professional does each day, and the value of security certifications.

1. Use the Internet to research information about working in the cybersecurity field. Then create a PowerPoint presentation that explains why cybersecurity employees are needed, what they do, and the value of security certifications. Your presentation should be seven to 10 slides in length.
2. As a follow-up to your presentation, create a Frequently Asked Questions (FAQ) sheet that outlines working in cybersecurity. Write a one-page FAQ about security employment.

References

1. Shi, Fleming, "Threat spotlight: Coronavirus-related phishing," *Barracuda*, Mar. 26, 2020, accessed Apr. 19, 2020, <https://blog.barracuda.com/2020/03/26/threat-spotlight-coronavirus-related-phishing/>.
2. "Fake 'Corona Antivirus' distributes BlackNET remote administration tool," *MalwareBytes Labs*, Mar. 23, 2020, accessed Apr. 19, 2020, <https://blog.malwarebytes.com/threat-analysis/2020/03/fake-corona-antivirus-distributes-blacknet-remote-administration-tool/>.
3. "McAfee Labs threats report," Dec. 2018, accessed Apr. 21, 2019, www.mcafee.com/enterprise/en-us/assets/reports/rp-quarterly-threats-dec-2018.pdf.
4. "2020 cyberthreat defense report," *Cyberedge Group*, accessed Apr. 20, 2020, <https://cyber-edge.com/cdr/>.
5. Morgan, Steve, "2019 official annual cybercrime report," *Cybersecurity Ventures*, accessed Apr. 20, 2020, www.herjavecgroup.com/wp-content/uploads/2018/12/CV-HG-2019-Official-Annual-Cybercrime-Report.pdf.
6. "2020 cyberthreat defense report," *Cyberedge Group*, accessed Apr. 20, 2020, <https://cyber-edge.com/cdr/>.
7. Hospelhorn, Sarah, "Solving the cybersecurity skills shortage within your organization," *Varonis*, Mar. 29, 2020, accessed Apr. 20, 2020, <https://www.varonis.com/blog/cybersecurity-skills-shortage/>.
8. "Information security analysts," *Bureau of Labor Statistics*, Apr. 10, 2020, accessed Apr. 30, 2020, www.bls.gov/ooh/computer-and-information-technology/information-security-analysts.htm.

9. Morgan, Steve, "One million cybersecurity job openings in 2016," *Forbes*, Jan. 2, 2016, accessed Feb. 16, 2017, www.forbes.com/sites/stevemorgan/2016/01/02/one-million-cybersecurity-job-openings-in-2016/#1118fc737d27.
10. "How CompTIA certifications can earn you higher salary and better opportunities," *Simplilearn*, Aug. 5, 2019, accessed Apr. 20, 2020, www.simplilearn.com/how-comptia-certification-can-earn-higher-salary-rar409-article.
11. "2019 insider threat report," *NucleusCyber*, retrieved Apr. 21, 2020, <https://info.nucleuscyber.com/2019-insider-threat-report>.
12. Fruhlinger, Josh, "Top cybersecurity facts, figures and statistics for 2020," *CSO*, Mar. 9, 2020, accessed Apr. 21, 2020, www.csoonline.com/article/3153707/top-cybersecurity-facts-figures-and-statistics.html.
13. "Phishing activity trends report," *Anti-Phishing Working Group*, accessed Apr. 25, 2020, <https://apwg.org/trendsreports/>.
14. McNichol, Tom, "Friend me on Facebook," *Bloomberg Businessweek*, Nov. 7, 2011.
15. Domabirg, Artem, "Bitsquatting: DNS hijacking without exploitation," *Diaburg.org*, accessed Mar. 27, 2017, dinaburg.org/bitsquatting.html.